Iteración 9 – Pruebas y Hardening

1. Objetivo

Ejecutar el plan de pruebas (Capítulos 11 y 12 del informe) y cerrar los aspectos de seguridad, midiendo la calidad con métricas basadas en ISO 25010.

2. Estrategia y alcance

Enfoque de **caja negra** basado en los requerimientos funcionales y en la trazabilidad con el proceso TO-BE, alineado con ISO 29119. Tipos de prueba: funcionales, integración, usabilidad, seguridad y control de acceso, geolocalización, rendimiento y regresión selectiva (motor de IA, cálculo de prioridad, algoritmo de rutas y máquina de estados).

Criterios de aceptación, suspensión y reanudación

Criterio	Condición
Aceptación	Al menos un caso por RF ejecutado; 100 % de los RF de prioridad alta ejecutados; ≥ 90 % de casos exitosos; sin defectos críticos que impidan el flujo TO-BE.
Suspensión	Defecto crítico que bloquea el flujo; más de 40 % de fallos en un módulo; ambiente de pruebas o IA no disponible.
Reanudación	Defecto crítico corregido y desplegado, verificado con retest; ambiente y datos estables.

Responsabilidades (RACI)

Actividad	Alex Lugo	Mauricio Segura	Grecia Vila	Asesor
Diseño de casos de prueba	RF-01 a RF-05 (R)	RF-06 a RF-10 (R)	RF-11 a RF-15 (R)	C
Ejecución de pruebas funcionales	R	R	R	I
Registro y seguimiento de defectos	R	R	R	I
Validación académica	I	I	I	A

R = Responsable · A = Aprueba · C = Consultado · I = Informado. El rol de Líder de Pruebas (coordinación y seguimiento) debe designarse entre los integrantes.

3. Automatización con Cypress

Spec	Flujo cubierto	RF
`auth.cy.js`	Login exitoso, fallido y acceso denegado por rol.	RF-11
`report-incident.cy.js`	Reporte con foto y GPS; validaciones de datos incompletos.	RF-01, 02
`routes.cy.js`	Generar, revisar, aprobar y asignar una ruta.	RF-03, 04
`driver-flow.cy.js`	Consultar ruta, iniciar, subir evidencia; aprobación del admin.	RF-05
`disposal-reports.cy.js`	Registrar peso, comprobante y coherencia del reporte.	RF-06 a 08
`admin-management.cy.js`	Contratos, vehículos, asignaciones y horarios.	RF-09, 10, 12–14

Las credenciales de prueba se pasan por variables de entorno de Cypress, nunca dentro del repositorio. Las pruebas de servicios se complementan con una colección de Postman y las pruebas unitarias/integración con PHPUnit.

4. Pruebas de seguridad (OWASP Top 10)

Riesgo OWASP	Verificación en EcoCiudad	Resultado
A01 Control de acceso roto	Acceder con un rol a endpoints de otro rol; manipular IDs (IDOR) de incidencias y rutas.	Pendiente
A02 Fallas criptográficas	HTTPS/TLS, hash Bcrypt, cifrado de contratos.	Pendiente
A03 Inyección	SQLi y XSS en descripción, formularios de contratos y vehículos.	Pendiente
A04 Diseño inseguro	Revisión de reglas de negocio (RN-01 a RN-08) y límites de tasa.	Pendiente
A05 Configuración incorrecta	`APP_DEBUG=false`, sin `.env` expuesto, cabeceras HSTS/CSP/X-Frame-Options.	Pendiente
A06 Componentes vulnerables	`composer audit` y `npm audit`.	Pendiente
A07 Fallas de autenticación	Fuerza bruta, expiración de JWT, políticas de contraseña.	Pendiente
A08 Integridad de software y datos	Validación de archivos subidos; dependencias de fuentes confiables.	Pendiente
A09 Fallas de logging y monitoreo	Revisión de logs de auditoría (5.5.6): rutas, estados, contratos, vehículos.	Pendiente
A10 SSRF	La URL del servicio de IA es fija y de configuración; no la controla el usuario.	Pendiente

5. Resultados y métricas de calidad

Métrica	Fórmula	Meta	Valor obtenido
Tasa de éxito	Casos exitosos ÷ casos ejecutados × 100	≥ 90 %	[completar]
Cobertura de RF	RF con ≥ 1 caso ejecutado ÷ 15 × 100	100 %	[completar]
Tasa de defectos	Defectos encontrados ÷ casos ejecutados	Tendencia decreciente	[completar]
Defectos críticos abiertos	Conteo al cierre	0	[completar]
Cobertura de código	Reporte de cobertura de PHPUnit	[definir umbral]	[completar]
Estabilidad	Ejecuciones de Cypress sin fallos consecutivas	3 de 3	[completar]

Evaluación según ISO 25010

Característica	Cómo se evalúa en EcoCiudad
Adecuación funcional	Cobertura de los RF-01 a RF-15 y resultado de las pruebas funcionales.
Eficiencia de desempeño	Ruta generada en ≤ 5 s; tiempos de respuesta de la API.
Usabilidad	Reporte en ≤ 3 pasos; resultados de la prueba de usabilidad.
Seguridad	Resultados OWASP, RBAC, cifrado y auditoría.
Fiabilidad	Estabilidad de las ejecuciones y disponibilidad 24/7.
Compatibilidad / Portabilidad	Chrome, Edge, Firefox; Windows, Android, iOS; despliegue con Docker.